Offline-First Cryptographic QR Identity Wallet for Rural Public Services

Technical report on the engineering of the solution to COEN838 Question 4

Report details

Item	Detail
Report number	QRW-TR-07, version 1.1
Date	6 November 2026
Prepared by	Aliyu Sarki Iliyasu (P25EGCP8040)
Course	COEN838 Advanced Software Engineering, project examination, Question 4
Institution	Department of Computer Engineering, Ahmadu Bello University, Zaria
Source code	https://github.com/sarki94/qr-identity-wallet
Companion documents	QRW-SRS-01, QRW-SDD-02, QRW-SEC-03, QRW-TST-04, QRW-PRM-05, QRW-USR-06
Status	Final for submission

Abstract

Rural citizens in Nigeria are often refused public services because online NIN verification fails where there is no network. This report describes the engineering of an offline-first cryptographic QR identity wallet, applied to the collection of subsidised fertiliser in Kura LGA, Kano State. A farmer receives an Ed25519-signed credential held in a phone wallet or printed on paper; the agent's phone verifies it with no network by checking the signature, a challenge–response that proves the wallet is not a copy, a cached signed revocation list and a face check, and later uploads each record to a hash-chained audit log. The prototype (core library, five services, one progressive web app) meets 43 of 48 requirements in full and 5 in part; 94 automated test cases pass; and the final security scan has no high- or medium-risk finding. The report states the assumptions made, the process followed, the results, the issues met and the work that remains.

Keywords: offline-first, digital identity, Ed25519, QR code, revocation, STRIDE, test-driven development

TABLE OF CONTENTS

1. EXECUTIVE SUMMARY....1
2. PROJECT OVERVIEW....1
2.1 Problem Statement....1
2.2 Objectives....1
2.3 Scope....2
2.4 Deliverables....2
3. ASSUMPTIONS....2
4. ENGINEERING APPROACH....4
4.1 Development Methodology....4
4.2 Phases and Timeline....4
4.3 Standards and Conventions Followed....4
4.4 Toolchain....5
5. SOLUTION DELIVERED....5
5.1 System Overview....5
5.2 Key Technical Decisions....6
5.3 Code Base....6
6. ENGINEERING WORK BY RUBRIC AREA....6
7. VERIFICATION AND RESULTS....7
7.1 Requirements Status....7
7.2 Test Results....8
7.3 Non-Functional Targets....8
7.4 Security Results....8
7.5 Demonstration Readiness....8
8. ISSUES AND RESOLUTIONS....9
9. KNOWN LIMITATIONS AND OPEN ITEMS....9
10. RECOMMENDATIONS....10
11. COMPLIANCE AND ETHICAL CONSIDERATIONS....10
12. STATEMENT ON THE USE OF AI....10
13. REFERENCES....11
APPENDIX A: REPOSITORY STRUCTURE....13
APPENDIX B: ABBREVIATIONS....14

1. EXECUTIVE SUMMARY

The task was to engineer, with the methods of Modules I to V, a working solution to the problem that online identity checks fail in rural Nigeria. The delivered system moves the trust decision from the server to the agent's phone: credentials are signed once, online, at the LGA office, and verified anywhere, offline, in milliseconds. Revocation and audit synchronise whenever a signal is available. Table 1.1 gives the outcome at a glance.

Table 1.1: Outcome at a glance

Area	Outcome
Working software	Core library, five services and a progressive web app; runs on one laptop with one launcher, or on phones over HTTPS
Requirements	48 requirements: 43 implemented, 5 partial; all traced to tests or manual verification
Testing	94 test cases, 145 checks, all passing; coverage 97% (core), 97% (services)
Security	19 STRIDE threats mitigated; OWASP ZAP: 0 High, 0 Medium after fix; no open static-analysis or dependency findings
Schedule	Schedule performance index 0.95 on 4 November after recovering from 0.25
Open items	Field test on a real phone; five partial requirements (Section 9)

2. PROJECT OVERVIEW

2.1 Problem Statement

The examination states the problem as follows: *"Rural citizens in Nigeria often cannot access public services (e.g., local clinics, agricultural subsidies) because online NIN/BVN verification fails due to poor network connectivity."*

2.2 Objectives

Table 2.1: Project objectives and status

ID	Objective	Status
O1	Verify a citizen's identity at the point of service with no network	Met
O2	Prevent forged, altered and copied credentials from being accepted	Met
O3	Allow credentials to be withdrawn, reaching offline points as soon as they sync	Met, with a bounded delay
O4	Keep a tamper-evident record of every verification	Met
O5	Include citizens with shared phones or no smartphone	Met
O6	Protect personal data in line with the Nigeria Data Protection Act 2023	Met in design; procedures for rollout
O7	Produce the artefacts and evidence required by the examination	Met

2.3 Scope

Table 2.2: Scope

In scope	Out of scope
Enrolment against NIN (mock NIMC) and credential issuance	Entitlement: quantities and whether a farmer has already collected (Question 3)
Smartphone wallet (L2) and paper wallet (L1)	BVN or any banking data
Offline verification, revocation, synchronisation and audit	Biometric matching by software
Staff authentication and role-based access	Native app-store apps; real NIMC integration

2.4 Deliverables

Table 2.3: Deliverables

Item	Where
Running source code and build instructions	GitHub repository; README; QRW-USR-06
Software Requirements Specification with UML and RTM	QRW-SRS-01
Design documentation (architecture, ERD, communication, scalability)	QRW-SDD-02
Threat model, secure design and security testing	QRW-SEC-03
Test strategy, test cases and results	QRW-TST-04
Risk register, maintenance plan and delivery metrics	QRW-PRM-05
User manual and installation guide	QRW-USR-06
Technical report (this document)	QRW-TR-07

3. ASSUMPTIONS

Instruction D of the examination requires every assumption made in interpreting the problem to be stated. Table 3.1 gives the interpretation of the problem; Table 3.2 gives the operating assumptions the design relies on.

Table 3.1: Assumptions in interpreting the problem

ID	Assumption	Reason
IA1	"Rural public services" is addressed through one concrete service, the collection of subsidised fertiliser; clinic attendance is a secondary case using the same mechanism.	Both are named in the problem; a concrete case gives testable requirements and matches the author's own observation.
IA2	"Offline-first" applies to verification at the point of service. Enrolment and issuance happen online at an LGA office.	Issuance needs NIMC and must protect the signing key, which is unsafe on a field device.
IA3	The credential proves identity only, not entitlement.	Entitlement is the subject of Question 3; separation keeps the identity layer reusable.
IA4	BVN is not used.	Identity is anchored on the NIN; banking data in a QR seen by every agent breaches data minimisation.
IA5	"Wallet" means a holder-controlled phone app; a printed paper wallet extends it to farmers without smartphones.	The problem names a wallet; elicitation found shared and feature phones common.
IA6	A progressive web app is acceptable as the app.	It works offline, installs to the home screen and uses the camera without app-store distribution.
IA7	Fictional NIMC records and demonstration accounts are acceptable for an examination prototype.	Real NIMC access is licensed; no real personal data was used.

Table 3.2: Operating assumptions

ID	Assumption	Consequence if false
AS1	NIMC is represented by a mock service; production integration requires NIMC licensing.	The Issuer calls the real interface; credentials and verifiers are unchanged.
AS2	The issuer key is an encrypted file in the prototype; production uses a hardware security module.	Higher key-compromise risk (PD-2).
AS3	L2 holders have an Android phone (own or shared) with a camera; others use the L1 paper wallet.	More L1 use, lower assurance.
AS4	Agents are given an Android smartphone by the programme.	Verification cannot run at that point.
AS5	Distribution points get at least intermittent connectivity within seven days.	Revocations arrive later; the 30-day refusal applies.
AS6	Entitlement is managed by a separate programme system.	Scope would extend into Question 3.
AS7	Proxy collection is prohibited by programme policy, as observed in Kura.	A delegation feature would be needed.
AS8	Enrolment takes place at an office with connectivity.	Offline issuance would need a different key-protection design.

4. ENGINEERING APPROACH

4.1 Development Methodology

An iterative, Agile-style process was used, adapted to a solo developer and a fixed deadline: requirements and models first, then daily increments that each ended in a tested build, with a written sprint plan, an agreed scope cut list, daily earned-value tracking and a decision log. The security-critical core was built test-first. Waterfall was rejected because problems with how the browser and the server agree on signatures had to surface on the day they appeared, not at the end.

4.2 Phases and Timeline

Table 4.1: Phases and timeline

Date	Phase	Output
22 Oct 2026	Inception	Question chosen (D1); course formats collected from the lecture notes; service split (D3)
25 Oct 2026	Requirements and modelling	Elicitation localised to Kura LGA; two assurance levels (D2a); UML models
30 Oct 2026	Design and core	Credential format (D9); test strategy (D10); core library test-first; CI
3 Nov 2026	Construction	Five services; web app; security tests; generated RTM; repository on GitHub, CI green
4 Nov 2026	Verification and documentation	OWASP ZAP scan and fix; coverage; SRS, design, security, test, project and user documents
5–7 Nov 2026	Transition	Phone test, review, slides and rehearsal

4.3 Standards and Conventions Followed

Table 4.2: Standards and conventions

Area	Standard or convention
Requirements	Lecturer's six-section SRS; FR/NFR classification; MoSCoW; four-column RTM
Design	IEEE 1016 viewpoints; UML 2 (use case, sequence, class, state machine)
Security	STRIDE in the lecturer's four-column format; OWASP Top 10; NDPA 2023
Testing	IEEE 829 test plan and summary report; test IDs tagged with requirement IDs
Cryptography and encoding	RFC 8032 (Ed25519), RFC 9285 (Base45), RFC 7914 (scrypt), RFC 8018 (PBKDF2)
Code and documents	PEP 8 (Flake8); TypeScript strict mode; Git with descriptive commits; department writing style

4.4 Toolchain

Table 4.3: Tools used

Purpose	Tools
Modelling	PlantUML (sources in the repository)
Implementation	Python, FastAPI, SQLAlchemy, cryptography, PyJWT; React, TypeScript, Vite, @noble/ed25519
Testing	pytest, Hypothesis, Vitest, Playwright
Quality and security	Flake8, Bandit, pip-audit, npm audit, OWASP ZAP
Build, CI and delivery	Git, GitHub, GitHub Actions, Docker Compose
Documentation	Scripts that generate the RTM, test catalogue, charts and all seven Word documents from the repository

5. SOLUTION DELIVERED

5.1 System Overview

Figure 5.1 shows the components. The Issuer is the only holder of the signing key; Trust publishes keys and the signed revocation list; Audit collects records into a hash chain; Auth issues staff tokens. Wallet and Verifier talk to each other only through QR codes, with no network.

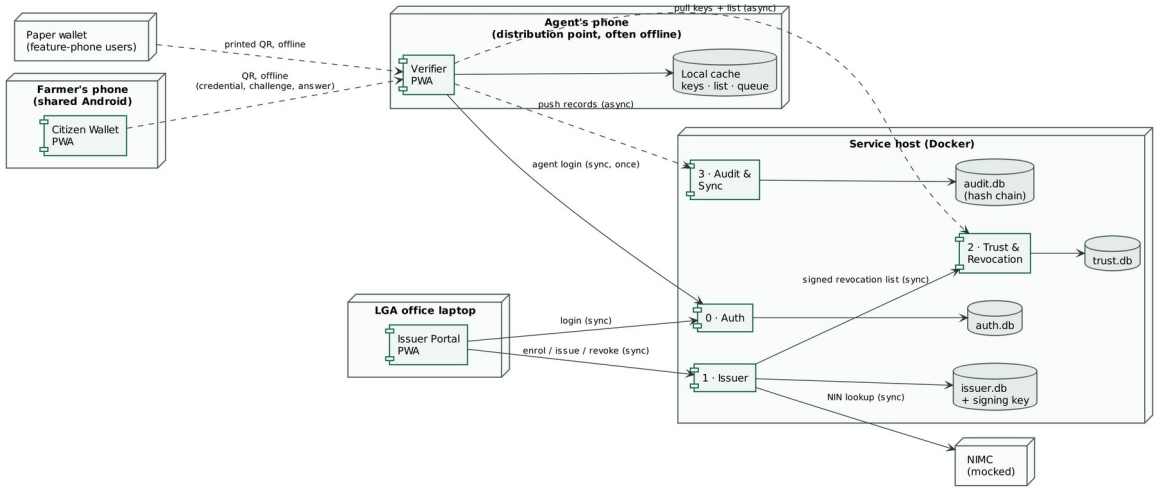


Figure 5.1: Components of the delivered system

5.2 Key Technical Decisions

Table 5.1: Key technical decisions

ID	Decision	Rationale
D2a	Two assurance levels on one credential format: L2 phone wallet, L1 paper wallet	Shared and feature phones are common (elicitation)
D3	Services split on trust boundaries: Auth, Issuer, Trust, Audit, mock NIMC	Signing key isolated in one service
D6	No proxy presentation	Programme policy observed in Kura
D8	Atomic re-issue in one transaction	Never two active credentials, nor none
D9	Sign exact payload bytes; QR = "QRW1:" + Base45(zlib(signature ‖ payload))	No cross-language mismatch; compact QR
D11	Issuer signs the revocation list; Trust only verifies and publishes it	Trust cannot forge or roll back a list
D12	Database per service; EdDSA staff tokens verified with Auth's public key	Services check tokens but cannot mint them
D13	NIN stored as a keyed hash plus masked copy	A stolen database reveals no NIN
D14	Strict RFC 8032 in the browser; one HTTPS origin for phones	Browser and server accept the same signatures

5.3 Code Base

Table 5.2: Code base summary

Part	Technology	Content
qrw_core	Python	Signing, verification, QR format, challenge–response, revocation list, hash chain
Services	FastAPI, SQLite / PostgreSQL	Auth, Issuer, Trust and Revocation, Audit and Sync, mock NIMC; Docker image
Web app	React, TypeScript	Wallet, Verifier, Issuer Portal, Audit, Guided Demo; works offline
Size and history		About 2,400 lines of production code; version history from 30 October 2026 with test-first commits

6. ENGINEERING WORK BY RUBRIC AREA

Table 6.1 summarises what was done in each area of the marking rubric and where the evidence is.

Table 6.1: Work performed and evidence

Area	Work performed	Evidence
Requirements and traceability (Module I)	Ethnographic elicitation (non-participant observation in Kura LGA, 2024 wet season) triangulated with published sources; 29 FR and 19 NFR with MoSCoW priorities; use-case, sequence, class and state models; RTM generated from test tags	QRW-SRS-01, Appendix A
Architecture and design (Module III)	Offline-first edge verification with a service-oriented back end; four styles compared; ERD with database per service; synchronous, asynchronous and offline patterns justified; scalability and failure modes analysed	QRW-SDD-02
Security engineering (Module IV)	STRIDE on six trust boundaries (19 threats); least privilege, defence in depth, fail securely; offline holder authentication and staff RBAC; SAST, dependency scans, security tests, OWASP ZAP	QRW-SEC-03
Implementation	Working core, services and web app; one-click launcher; Docker; phone mode over HTTPS	Repository; QRW-USR-06
Testing and QA (Module II)	TDD with red–green commits; property-based, cross-implementation, integration, security and browser system tests; CI with coverage gates	QRW-TST-04
Project and risk management (Module V)	Sprint plan and cut list; earned value; burndown; technical debt ratio; risk register (RE = P × L); maintenance plan by class	QRW-PRM-05

7. VERIFICATION AND RESULTS

7.1 Requirements Status

43 requirements are implemented in full. Table 7.1 lists the five that are partial and what is missing.

Table 7.1: Partially met requirements

Requirement	Missing part
FR-14	Agent PIN unlock of the seven-day offline token
FR-27	Multi-factor authentication for staff (cut from the schedule)
NFR-S3	TLS between services (prototype runs them on one host)
NFR-S8	Organisational procedures: recorded consent, impact assessment
NFR-U1	Full Hausa interface (verdicts only are in Hausa)

7.2 Test Results

Table 7.2: Test results

Measure	Result
Automated test cases / checks	94 / 145, all passing
Browser system tests	TC-SYS-002 11/11; TC-SYS-003 16/16 (re-run 4 November)
Statement coverage	Core 97%; services 97%; browser verifier 90%; PIN vault 100%
Defects found / open	7 / 0

7.3 Non-Functional Targets

Table 7.3: Measured against targets

Requirement	Target	Measured
NFR-P1 offline verification	≤ 3 s	0.32 ms (Python); 4.3 ms (browser library)
NFR-P2 issuance	≤ 5 s	8 ms
NFR-C3 100,000-entry revocation list	≤ 2 MB	0.94 MB in transit; 1.41 MB on the phone
NFR-C2 five wallet profiles	≤ 5 MB	3.4 KB
NFR-C4 daily records upload	2,000 in one request	Accepted; chain intact

7.4 Security Results

Table 7.4: Security results

Check	Result
Bandit (SAST)	0 open; one false positive triaged, one finding fixed
pip-audit / npm audit	0 known vulnerabilities in shipped packages
Security test cases	24 checks (TC-SEC-001 to 012), all passing
OWASP ZAP (authenticated, full active scan)	Before: 1 Medium. After fix: 0 High, 0 Medium, 1 Low accepted

7.5 Demonstration Readiness

The Guided Demo runs the whole distribution day on one laptop against the live services and was run end to end by the candidate on his own Windows laptop. The same application runs on Android phones over HTTPS on a local network for a field-style demonstration.

8. ISSUES AND RESOLUTIONS

Table 8.1 records the significant issues met during the project and how each was resolved.

Table 8.1: Issues log

ID	Issue	Impact	Resolution
IS-1	Three planned days with no sprint work (SPI 0.25 on 2 Nov)	Deadline risk	Re-plan, work pulled forward, cut list applied; SPI 0.95 on 4 Nov
IS-2	Python packages would not install on the candidate's Windows laptop	Setup blocked	Corrected install paths and a fallback; README and manual updated
IS-3	Services not running during manual testing gave confusing errors	Demo risk	One-click launcher and the Guided Demo
IS-4	Valid QR codes rejected because the scanner trimmed meaningful spaces (DEF-01)	Genuine farmers refused	Fixed; clearer messages per code type; regression tests
IS-5	100,000-entry revocation list 2.40 MB, over budget (DEF-02)	Capacity target missed	Compression in transit and on the phone
IS-6	Advisories in a web routing dependency (DEF-03)	Security	Dependency removed; internal router
IS-7	No Content-Security-Policy on API documentation pages (DEF-04, DEF-05)	Security	Fixed test-first; documentation switch for production
IS-8	Navigation tabs overflowed on phone screens	Usability	Layout fixed; system tests re-run
IS-9	Git file-lock prompts on Windows	Workflow friction	Answer "n"; disable automatic housekeeping

9. KNOWN LIMITATIONS AND OPEN ITEMS

Table 9.1: Limitations and open items

Item	Impact	Plan
Field test on a real Android phone	Performance and camera use not yet confirmed on target hardware	Before the defence (npm run phone)
Five partial requirements (Section 7.1)	Lower staff assurance; Hausa limited to verdicts	Maintenance plan, QRW-PRM-05
Mock NIMC, SQLite, file-based signing key	Not production-grade	NIMC integration, PostgreSQL, HSM
Revocation reaches offline points only on sync	Revoked credential may pass for up to 30 days	Delta lists over SMS or USSD
Browser system tests run by hand, not in CI	Regressions in screens found later	Add to CI
Elicitation by one observer; no usability test with users	Usability claims rest on inspection	Think-aloud evaluation in a pilot

10. RECOMMENDATIONS

1. Run a field pilot at one distribution point in Kura LGA with a think-aloud usability evaluation of the Verifier.
2. Before any pilot, add staff multi-factor authentication and the full Hausa interface.
3. For production, integrate the real NIMC interface, move to PostgreSQL, hold the issuer key in a hardware security module and enable mutual TLS between services.
4. Carry out a data protection impact assessment and define the consent procedure for enrolment.
5. Introduce delta revocation lists to shorten the revocation delay at offline points.
6. Add the browser system tests and the ZAP scan to continuous integration.

11. COMPLIANCE AND ETHICAL CONSIDERATIONS

- **Data protection.** The credential carries a masked NIN only, with no BVN, telephone number or date of birth; the full NIN is never stored; audit records hold identifiers, not personal details.
- **Inclusion.** Paper wallets for farmers without smartphones; separate PIN-protected profiles on shared phones; Hausa verdicts with colour and icons.
- **Human oversight.** The face check is made by a person, not by software, so no biometric model decides who is served; every rejection is recorded with its reason for review.
- **Honest evidence.** No field data was invented; personas are labelled illustrative; test data is fictional; every figure in this report is produced by a test or scan in the repository.

12. STATEMENT ON THE USE OF AI

Instruction F requires responsible and ethical use of AI. This section states how AI was used, what the candidate did, and how the work was checked.

Table 12.1: Use of AI in the project

Aspect	Statement
Tool	Claude, an AI assistant by Anthropic, used as a working collaborator in sessions directed by the candidate. AI-assisted commits carry a Co-Authored-By trailer.
What the AI did	Discussed and critiqued options (question choice, architecture, security, testing); drafted the elicitation write-up from the candidate's account; wrote most of the code, tests, UML drafts and document drafts; ran the tests and scans and fixed defects found; prepared setup guides.
What the candidate did	Chose the question and case study; supplied the field observation from Kura LGA; made or approved every decision in the decision log; gathered the lecturer's formats from the course materials; set up and tested the system on his own laptop and surfaced defect DEF-01; reviewed the documents; owns the submission and its defence.
Safeguards	Code accepted only when it passed tests, coverage gates and scans in CI; no invented observations, users or measurements; AI use declared here and in the version history; design choices explained to the candidate so that he can defend them.

13. REFERENCES

African Farming. (2026). *Katsina launches fertiliser scheme to strengthen 2026 farming season*. https://africanfarming.net/crops/agriculture/katsina-launches-fertiliser-scheme-to-strengthen-2026-farming-season

Fältström, P., Ljunggren, F., & van Gulik, D.-W. (2022). *The Base45 data encoding* (RFC 9285). Internet Engineering Task Force. https://doi.org/10.17487/RFC9285

IEEE. (2008). *IEEE standard for software and system test documentation* (IEEE Std 829-2008). Institute of Electrical and Electronics Engineers.

IEEE. (2009). *IEEE standard for information technology — Systems design — Software design descriptions* (IEEE Std 1016-2009). Institute of Electrical and Electronics Engineers.

Josefsson, S., & Liusvaara, I. (2017). *Edwards-curve digital signature algorithm (EdDSA)* (RFC 8032). Internet Engineering Task Force. https://doi.org/10.17487/RFC8032

Nigeria Data Protection Commission. (2023). *Nigeria Data Protection Act, 2023*. Federal Republic of Nigeria.

Nwaobiala, C. U., & Ubor, V. U. (2019). Effectiveness of electronic wallet system of Growth Enhancement Support Scheme distribution among arable crop farmers

in Imo State, South-Eastern Nigeria. *Scientific Papers Series Management, Economic Engineering in Agriculture and Rural Development, 16*(1).

Sommerville, I. (2016). *Software engineering* (10th ed.). Pearson.

APPENDIX A: REPOSITORY STRUCTURE

Table A.1: Repository structure

Folder	Content
core/	qrw_core library and its tests
services/	Five FastAPI services, tests and the local launcher
web/	Progressive web app, browser-library tests and Playwright system tests
tools/	Requirements catalogue, RTM generator, test catalogue, ZAP scan script
docs/uml/	PlantUML sources for all diagrams
docs/evidence/	Test, coverage, performance, Bandit, audit and ZAP reports; CI screenshot
docs/build/	Generators for the seven Word and PDF documents (build_all.sh)
docs/deliverables/	The seven documents in Word and PDF
.github/workflows/	Continuous integration pipeline

APPENDIX B: ABBREVIATIONS

Table B.1: Abbreviations

Term	Meaning
CI	Continuous integration
DAST / SAST	Dynamic / static application security testing
FR / NFR	Functional / non-functional requirement
HSM	Hardware security module
L1 / L2	Assurance levels: paper wallet / smartphone wallet
LGA	Local Government Area
NIMC / NIN	National Identity Management Commission / National Identification Number
NDPA	Nigeria Data Protection Act 2023
PWA	Progressive web app
RBAC	Role-based access control
RTM	Requirements Traceability Matrix
SPI	Schedule performance index
TDD	Test-driven development